Ejercicio 1: Auditoría de seguridad activa con test de intrusión (Red local)

Objetivo: Detectar equipos y puertos abiertos en una red local, como primer paso de un test de intrusión.

Material necesario

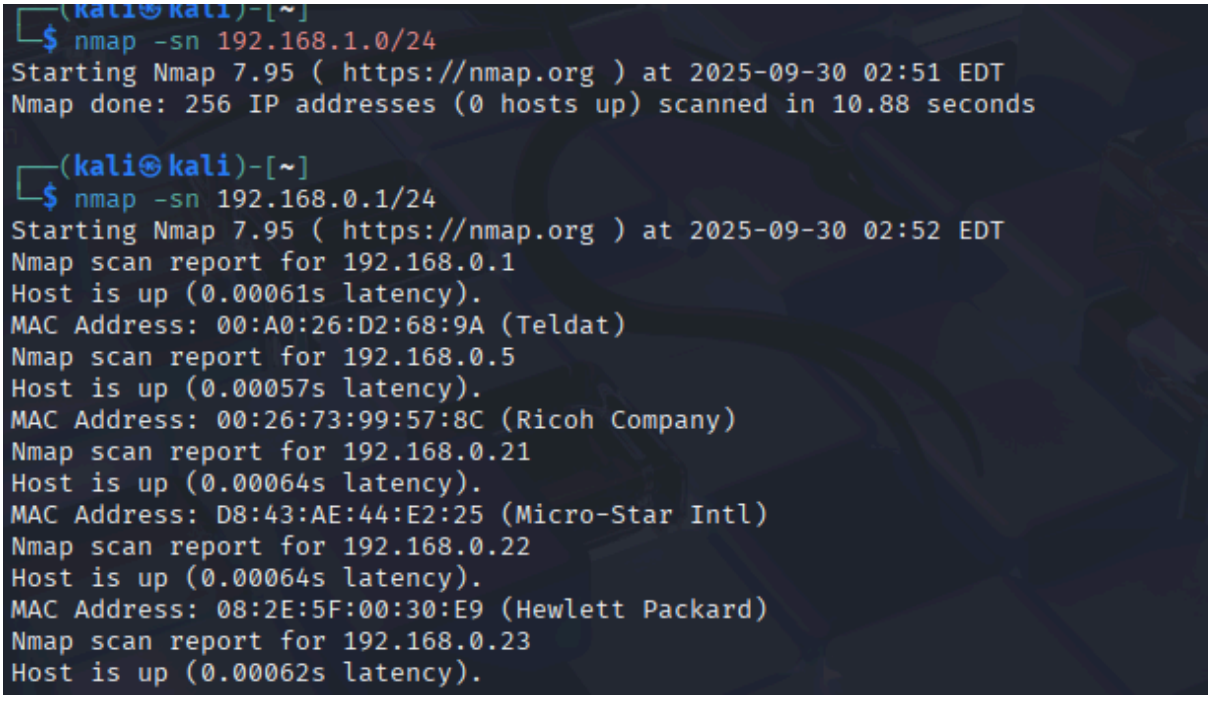
- Kali Linux.
- Acceso a una red local con al menos otro equipo conectado (puede ser una máquina virtual o el propio router).

Pasos

1. Escanea la red local para descubrir hosts activos:

   ### nmap -sn 192.168.1.0/24

(ajusta el rango según la red del aula).



2. Elige un host detectado (por ejemplo, la IP 192.168.1.20) y haz un escaneo de puertos:

   ### nmap -sV 192.168.1.20

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.0.21
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-30 02:55 EDT
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 71.00% done; ETC: 02:56 (0:00:06 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 79.65% done; ETC: 02:56 (0:00:04 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 86.00% done; ETC: 02:56 (0:00:03 remaining)
Nmap scan report for 192.168.0.21
Host is up (0.00054s latency).
All 1000 scanned ports on 192.168.0.21 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: D8:43:AE:44:E2:25 (Micro-Star Intl)

Service detection performed. Please report any incorrect results at https://nma
p.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.69 seconds
```

3. Opcional: Haz un escaneo más detallado incluyendo detección de sistema operativo:

nmap -A 192.168.1.20

```
┌──(kali㉿kali)-[~]
└─$ nmap -A 192.168.0.21
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-30 02:56 EDT
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 5.50% done; ETC: 02:57 (0:00:34 remaining)
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.00% done; ETC: 02:57 (0:00:11 remaining)
Stats: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 64.25% done; ETC: 02:57 (0:00:08 remaining)
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 70.00% done; ETC: 02:57 (0:00:06 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 79.00% done; ETC: 02:57 (0:00:05 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 86.00% done; ETC: 02:57 (0:00:03 remaining)
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 94.00% done; ETC: 02:57 (0:00:01 remaining)
Nmap scan report for 192.168.0.21
```

```
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 70.00% done; ETC: 02:57 (0:00:06 remaining)
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 79.00% done; ETC: 02:57 (0:00:05 remaining)
Stats: 0:00:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 86.00% done; ETC: 02:57 (0:00:03 remaining)
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 94.00% done; ETC: 02:57 (0:00:01 remaining)
Nmap scan report for 192.168.0.21
Host is up (0.00057s latency).
All 1000 scanned ports on 192.168.0.21 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: D8:43:AE:44:E2:25 (Micro-Star Intl)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT     ADDRESS
1   0.57 ms 192.168.0.21

OS and Service detection performed. Please report any incorrect results at http
s://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.48 seconds
```

Resultado esperado

- Listado de **IP activas** en la red.
- Identificación de **puertos abiertos** y servicios que están en ejecución.
- Información inicial sobre posibles puntos de entrada para un atacante.

🌐 Ejercicio 2: Auditoría básica de páginas web

Objetivo: Analizar vulnerabilidades comunes en una página web usando herramientas incluidas en Kali Linux.

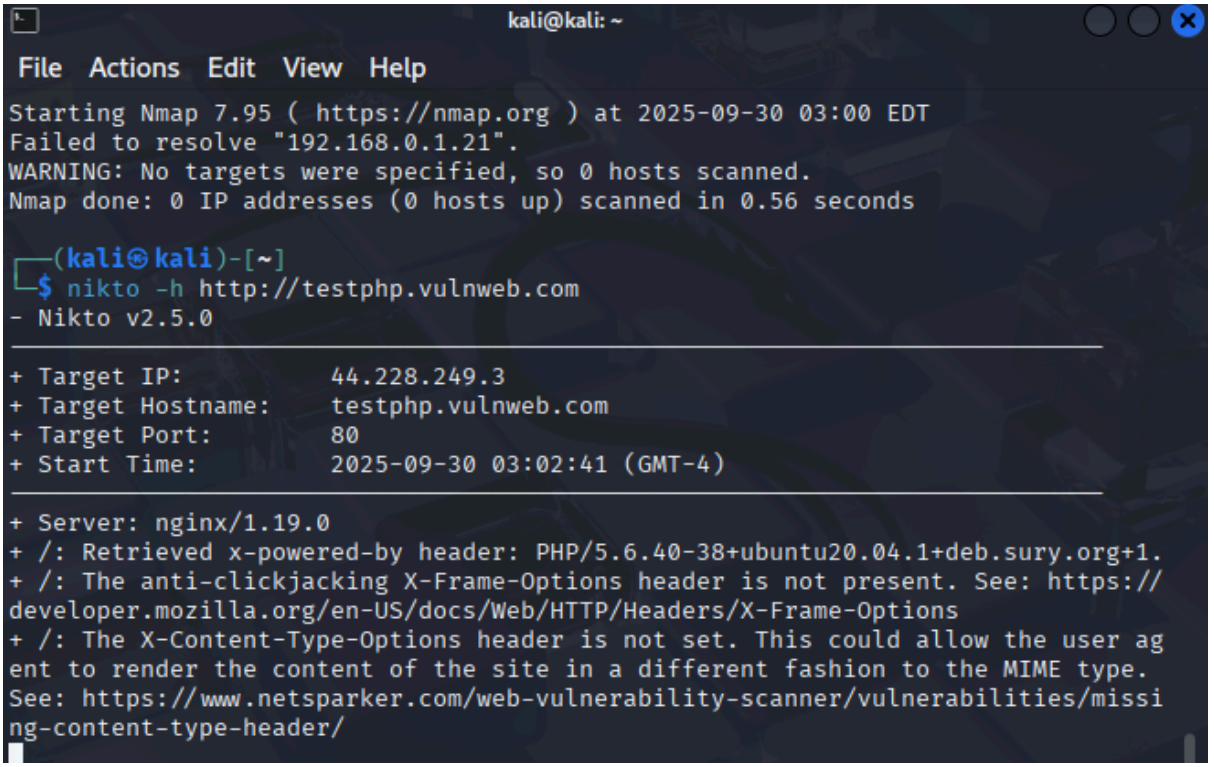
Material necesario

- Kali Linux.
- Una página web de pruebas (puede ser una aplicación vulnerable en local, como DVWA o WebGoat, o un sitio autorizado para prácticas, como **testphp.vulnweb.com**).

Pasos

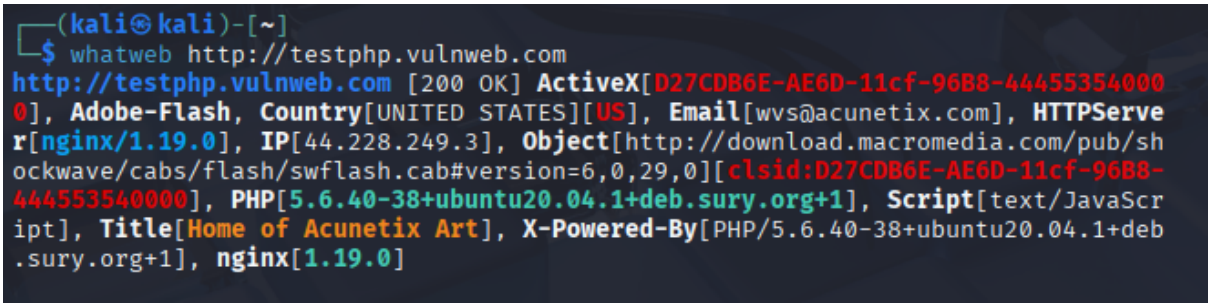
1. Haz un escaneo con **Nikto** para identificar configuraciones inseguras y vulnerabilidades:

   nikto -h http://testphp.vulnweb.com



2. Analiza con **WhatWeb** qué tecnologías usa el sitio (servidor, CMS, etc.):

   whatweb http://testphp.vulnweb.com



3. Opcional: Haz un escaneo con **sqlmap** para comprobar si un formulario es vulnerable a inyección SQL:

   sqlmap -u "http://testphp.vulnweb.com/artists.php?artist=1" --batch

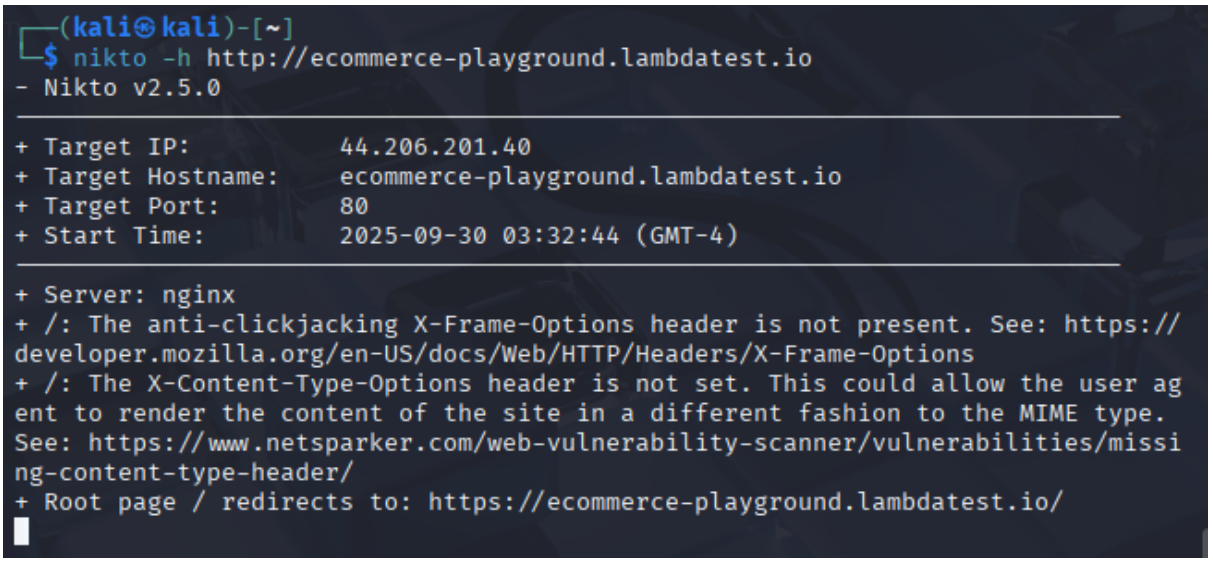


Resultado esperado

- Informe de posibles vulnerabilidades (cabeceras inseguras, directorios ocultos, configuraciones por defecto).
- Identificación de tecnologías utilizadas en la web (PHP, Apache, etc.).
- Detección (si la hay) de parámetros vulnerables a inyección SQL.

EJERCICIOS EN CLASE

1 Ejercicio



2. Hallazgos y Vulnerabilidades

Esta sección detalla los problemas de seguridad y la configuración del servidor web:

A. Redirección HTTP a HTTPS

- `Root page / redirects to: https://ecommerce-playground.lambdatest.io/`: Nikto detectó que la página principal (`/`) en el puerto 80 (HTTP) **redirige** inmediatamente al protocolo seguro HTTPS. Esto es una buena práctica de seguridad.

B. Cabeceras de Seguridad Faltantes

Nikto identifica dos importantes cabeceras HTTP que faltan y que representan vulnerabilidades de seguridad:

- `The anti-clickjacking X-Frame-Options header is not present`:
  - **Problema:** Falta la cabecera `X-Frame-Options`.
  - **Riesgo:** Esto podría permitir que el sitio web sea cargado en un `<iframe>` en una página maliciosa, exponiéndolo a un ataque de **clickjacking** (donde los usuarios hacen clic en

- **Problema:** Falta la cabecera `X-Frame-Options`.
- **Riesgo:** Esto podría permitir que el sitio web sea cargado en un `<iframe>` en una página maliciosa, exponiéndolo a un ataque de **clickjacking** (donde los usuarios hacen clic en elementos invisibles o engañosos).

- `The X-Content-Type-Options header is not set`:
  - **Problema:** Falta la cabecera `X-Content-Type-Options`.
  - **Riesgo:** Esto podría permitir a los navegadores modernos intentar "adivinar" el tipo de contenido (MIME-Type) de un archivo descargado. Si la adivinación es incorrecta, podría hacer que un navegador ejecute código (como HTML/JavaScript) que debería ser un archivo simple, lo que resulta en un ataque de **Cross-Site Scripting (XSS)**.

. Estructura de Directorios

- `No CGI Directories found`: Nikto no encontró directorios comunes utilizados para *scripts* CGI. El mensaje sugiere usar el parámetro `'-C all'` si se desea forzar una comprobación más exhaustiva de directorios.

Conclusión: El sitio está en línea y utiliza nginx, pero **necesita mejorar su endurecimiento de seguridad** añadiendo las cabeceras **`X-Frame-Options`** y **`X-Content-Type-Options`** a su configuración.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://ecommerce-playground.lambdatest.io

http://ecommerce-playground.lambdatest.io/ [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer[nginx], IP[44.206.201.40], RedirectLocation[https://ecommerce-playground.lambdatest.io/], Title[301 Moved Permanently], nginx

https://ecommerce-playground.lambdatest.io/ [200 OK] Bootstrap, Cookies[OCSESSID,currency,language], Country[UNITED STATES][US], HTML5, HTTPServer[nginx], IP[44.206.201.40], JQuery[3.6.0], Open-Graph-Protocol[website], PoweredBy[OpenCart], Script, Title[Your Store], X-Frame-Options[SAMEORIGIN], X-UA-Compatible[IE=edge], nginx
```

1. Primera Respuesta: Redirección Obligatoria (HTTP)

`http://ecommerce-playground.lambdatest.io/ [301 Moved Permanently]`

Esta primera línea muestra la respuesta del servidor al intentar acceder a la URL utilizando el protocolo HTTP estándar (no cifrado).

Detalle	Significado
`[301 Moved Permanently]`	Es el **código de estado HTTP** clave. Indica que el recurso solicitado ha sido movido de forma permanente a una nueva ubicación.
`RedirectLocation[https://ecommerce-playground.lambdatest.io/]`	El servidor informa al navegador (o a la herramienta) cuál es la nueva ubicación correcta, que es la versión **HTTPS** de la URL.
`HTTPServer[nginx]`	El servidor web que maneja la solicitud es **nginx**.
`Country[UNITED STATES][US]`	Ubicación geográfica y dirección IP del servidor.
`[200 OK]`	El **código de estado HTTP** estándar que indica que la solicitud fue exitosa. La herramienta ahora está viendo el contenido real del sitio.
`PoweredBy[OpenCart]`	El sitio está utilizando la plataforma de comercio electrónico **OpenCart**.
`Title[Your Store]`	Este es el título real que se muestra en la pestaña del navegador para la página principal.
`Cookies[OCSESSID,currency,language]`	El servidor está enviando cookies de sesión, moneda y configuración de idioma.
`JQuery[3.6.0], HTML5, Bootstrap`	Muestra las tecnologías de *frontend* y desarrollo web que utiliza el sitio.
`X-Frame-Options[SAMEORIGIN]`	Es un encabezado de seguridad que ayuda a prevenir ataques de *clickjacking*, indicando que el contenido solo puede ser incrustado en *frames* de la misma fuente.
`HTTPServer[nginx]`	Se confirma que el servidor nginx está sirviendo la página de forma segura.

Conclusión general: El servidor está en línea, utiliza **HTTPS** obligatoriamente, está alojado en EE. UU., se ejecuta con **nginx** y funciona con el sistema de comercio electrónico **OpenCart**.

Ejercicio 2

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://itsecgames.com/index.htm
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    itsecgames.com
+ Target Port:        80
+ Start Time:         2025-09-30 03:36:52 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache
+ /index.htm/: The anti-clickjacking X-Frame-Options header is not present. See
: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /index.htm/: The X-Content-Type-Options header is not set. This could allow t
he user agent to render the content of the site in a different fashion to the M
IME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabili
ties/missing-content-type-header/
```

2. Vulnerabilidades de Configuración (Riesgos Medios/Bajos)

Nikto detectó dos problemas con las cabeceras HTTP del servidor que deben corregirse:

1. **Falta** `X-Frame-Options`**:** La ausencia de esta cabecera expone el sitio a ataques de **Clickjacking**, permitiendo que la página sea incrustada en un `iframe` malicioso.
2. **Falta** `X-Content-Type-Options`**:** La falta de esta cabecera de seguridad podría permitir el **"MIME-sniffing"** del navegador, aumentando el riesgo de ataques de *Cross-Site Scripting (XSS)*.

---

3. Identificación de Tecnología (Información)

Nikto logró identificar la plataforma subyacente del sitio:

- **Identificación de Drupal 7:** El escáner determinó que el sitio probablemente está usando el Sistema de Gestión de Contenidos (CMS) **Drupal, versión 7**.
    - Esta identificación se basó en la presencia de la cabecera `x-generator` y la cabecera `Link` con valores específicos de Drupal.

Importancia: Conocer la versión exacta del CMS (**Drupal 7**) es valioso para un atacante, ya que puede buscar vulnerabilidades públicas y exploits conocidos específicos para esa versión. La recomendación es siempre actualizar o eliminar cabeceras de identificación innecesarias.

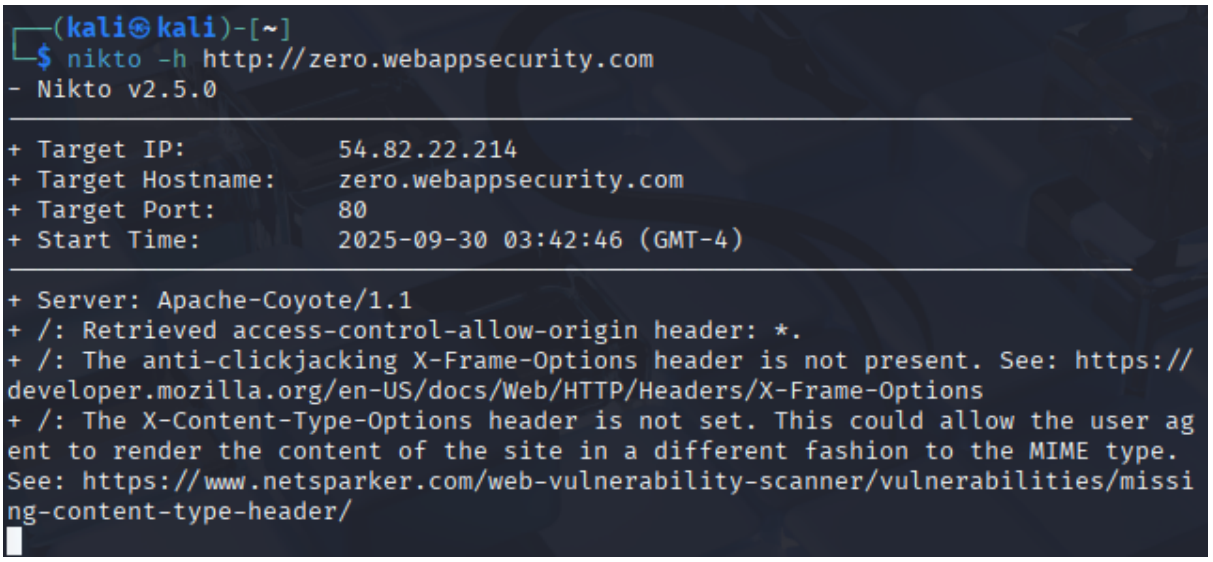
```
┌──(kali㉿kali)-[~]
└─$ whatweb http://itsecgames.com/index.htm
http://itsecgames.com/index.htm [200 OK] Apache, Country[NETHERLANDS][NL], HTML
5, HTTPServer[Apache], IP[31.3.96.40], Script, Title[bWAPP, a buggy web applica
tion!]
```

Desglose del Resultado

Detalle	Significado
`http://itsecgames.com/index.htm`	La URL específica que fue analizada.
`[200 OK]`	El **código de estado HTTP** clave. Indica que la conexión fue exitosa y el servidor entregó la página solicitada.
`IP[31.3.96.40], Country[NETHERLANDS][NL]`	El servidor se encuentra en la dirección IP `31.3.96.40` y está ubicado en **Países Bajos** (NETHERLANDS).
`HTTPServer[Apache]`	Confirma que el software de servidor web utilizado es **Apache**.
`HTML5, Script`	Indica las tecnologías de *frontend* utilizadas en la página.
`Title[bWAPP, a buggy web application!]`	El título de la página. Este es el dato más significativo, ya que revela que el sitio está ejecutando **bWAPP** (**B**uggy **W**eb **App**lication), una aplicación web con fallos de seguridad conocidos, que se utiliza típicamente para la formación en *hacking* ético y pruebas de penetración.

En resumen, el escaneo fue **exitoso**, proporcionó detalles tecnológicos (Apache, Drupal 7) y confirmó que las vulnerabilidades detectadas son apropiadas para un sitio de prueba de seguridad.

Ejercicio 3



1. Detalles del Objetivo y Servidor

Esta sección establece la conexión y la tecnología base:

- **Host y Puerto:** El escaneo se dirigió a `zero.webappsecurity.com` en la IP `54.82.22.214` a través del **Puerto 80**.
- **Servidor Inicial:** El servidor inicial se identifica como `Apache-Coyote/1.1` (típicamente asociado con Apache Tomcat).
- **Banner Modificado:** Nikto detecta que el banner del servidor **cambió durante el escaneo** a `Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40`. Esta inconsistencia puede indicar un problema de configuración o un intento de ofuscación, pero revela mucha información sobre la pila tecnológica (Apache 2.2.6 en Windows, versiones de OpenSSL).

2. Vulnerabilidades de Configuración Críticas

Nikto reporta fallos de configuración que representan riesgos directos:

A. Exposición de CORS y Clickjacking

- `Retrieved access-control-allow-origin header: *.` : El servidor permite el **Intercambio de Recursos de Origen Cruzado (CORS)** desde cualquier dominio (`*`). Esto puede ser peligroso si la aplicación no está diseñada para ello, exponiéndola a ataques *Cross-Site Request Forgery (CSRF)* o robo de datos.
- **Falta de** `X-Frame-Options` **:** El sitio es vulnerable al ataque de **Clickjacking**, ya que no impide que la página se cargue en un *iframe* malicioso.
- **Falta de** `X-Content-Type-Options` **:** La ausencia de esta cabecera aumenta el riesgo de ataques de **XSS** y fallos en la interpretación de contenido (*MIME-sniffing*).

B. Métodos HTTP Peligrosos Habilitados (Alto Riesgo)

El servidor tiene habilitados varios métodos HTTP que pueden permitir a un atacante interactuar peligrosamente con los archivos del servidor:

- **Métodos Permitidos:** `GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS, PATCH` .
- **Riesgos Específicos:**
  - `PUT` **method could allow clients to save files on the web server.** (Riesgo de subir *malware* o modificar archivos).
  - `DELETE` **may allow clients to remove files on the web server.** (Riesgo de borrado de contenido).
  - `PATCH` **may allow client to issue patch commands to server.** (Riesgo de modificar recursos parcialmente, según el RFC-5789).

Conclusión: El servidor `zero.webappsecurity.com` está **altamente desprotegido** o está configurado intencionalmente como un **entorno de pruebas vulnerable** (similar a bWAPP) debido a la gran cantidad de información expuesta y la habilitación de métodos HTTP inherentemente riesgosos. La presencia de métodos `PUT` y `DELETE` es una vulnerabilidad grave que debe ser corregida en cualquier entorno de producción.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://zero.webappsecurity.com
http://zero.webappsecurity.com [200 OK] Apache, Bootstrap, Content-Language[en-US], Country[UNITED STATES][US], HTML5, HTTPServer[Apache-Coyote/1.1], IP[54.82.22.214], JQuery[1.8.2], Script[text/javascript], Title[Zero - Personal Banking - Loans - Credit Cards], UncommonHeaders[access-control-allow-origin], X-UA-Compatible[IE=Edge]
```

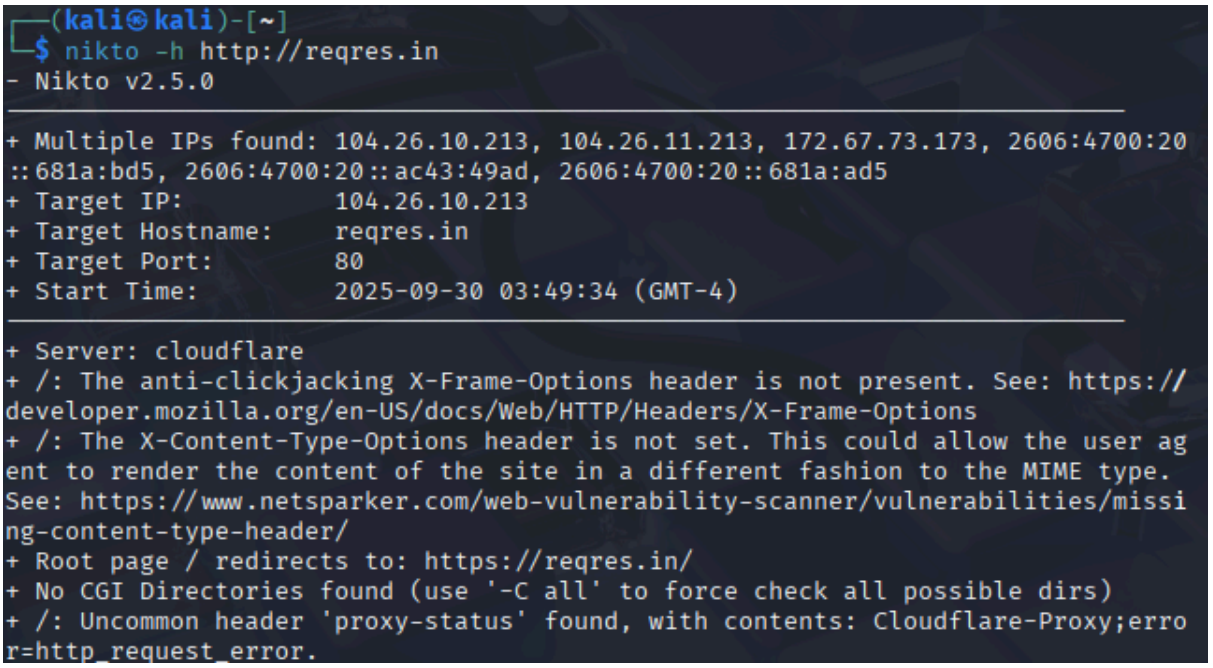
Detalle	Significado
`http://zero.webappsecurity.com`	La URL base que fue analizada.
`[200 OK]`	El código de estado HTTP estándar. Indica que la conexión fue **exitosa** y el servidor entregó la página principal sin problemas.
`IP[54.82.22.214], Country[UNITED STATES][US]`	El servidor está ubicado en los **Estados Unidos** y su dirección IP es `54.82.22.214`.
`HTTPServer[Apache-Coyote/1.1]`	El servidor web utiliza **Apache-Coyote 1.1**, que es el motor HTTP de **Apache Tomcat** (un servidor de aplicaciones Java).
`Title[Zero - Personal Banking - Loans - Credit Cards]`	El título de la página principal indica que el sitio simula ser una aplicación de **banca personal**.
`JQuery[1.8.2], Bootstrap, HTML5`	Las tecnologías de *frontend* utilizadas incluyen las librerías populares **JQuery** y **Bootstrap**.
`UncommonHeaders[access-control-allow-origin]`	La herramienta notó la presencia de la cabecera `access-control-allow-origin`, confirmando el uso de CORS (visto en el escaneo de Nikto como `*`).

Conclusión

El sitio `zero.webappsecurity.com` es una aplicación web en funcionamiento que simula un portal de **banca personal**. Está construido sobre el servidor de aplicaciones **Apache Tomcat (Coyote 1.1)**.

Junto con el informe de Nikto anterior, este resultado confirma que el sitio es muy probablemente un **entorno de prueba de vulnerabilidades** (un 靶场 o *security lab*), ya que combina una apariencia de aplicación financiera real con **graves fallos de seguridad** (como la exposición de métodos HTTP peligrosos y cabeceras inseguras) que ningún banco real mantendría en producción.

Ejercicio 4



1. Detalles del Objetivo

Esta sección revela información clave sobre la infraestructura de *hosting*:

- **Múltiples IPs:** Nikto encontró **varias direcciones IP** (IPv4 e IPv6) asociadas al *hostname* (`104.26.10.213`, `104.26.11.213`, etc.). Esto es una señal fuerte de que el sitio está detrás de un **balanceador de carga** o una **Red de Entrega de Contenido (CDN)**.
- **Target IP:** El escaneo real se dirigió a una de ellas: `104.26.10.213`.
- **Target Port:** El escaneo comenzó en el **Puerto 80** (HTTP).
- **Server:** El software del servidor se identifica como `cloudflare`. Esto confirma que el sitio está utilizando la CDN y los servicios de protección de Cloudflare, lo que significa que Nikto está escaneando el **servidor proxy de Cloudflare**, no el servidor de origen real.

2. Hallazgos y Vulnerabilidades

Nikto detectó varios problemas de configuración que son comunes incluso detrás de CDNs:

- **Redirección HTTP:** El sitio **redirige correctamente** la página raíz (`/`) a la versión segura **HTTPS** (`https://reqres.in/`).
- **Cabeceras de Seguridad Faltantes (Crítico):**
  - **Falta** `X-Frame-Options` **:** El sitio es vulnerable al ataque de **Clickjacking**, ya que no impide que la página se cargue dentro de un *iframe* en otro sitio.
  - **Falta** `X-Content-Type-Options` **:** La omisión de esta cabecera aumenta el riesgo de problemas de **XSS** al permitir que los navegadores "adivinen" el tipo de contenido (MIME-sniffing).
- **Cabecera Rara:**
  - `Uncommon header 'proxy-status' found...` : Se detectó una cabecera inusual (`proxy-status`) con un error de Cloudflare (`http_request_error`). Esto podría indicar un problema de comunicación entre el *proxy* de Cloudflare y el servidor de origen real en el momento del escaneo.

Conclusión

El sitio **`reqres.in`** utiliza la infraestructura de **Cloudflare** como CDN y capa de seguridad. Aunque la redirección a HTTPS es correcta, el sitio (o la configuración de Cloudflare) **falla en implementar dos cabeceras de seguridad HTTP fundamentales** (`X-Frame-Options` y `X-Content-Type-Options`), dejando a los usuarios y a la aplicación vulnerables a ataques web comunes como el *Clickjacking* y el *Cross-Site Scripting (XSS)*.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://reqres.in
http://reqres.in [301 Moved Permanently] Country[RESERVED][ZZ], HTTPServer[clou
dflare], IP[172.67.73.173], RedirectLocation[https://reqres.in/], UncommonHeade
rs[report-to,nel,cf-ray]
https://reqres.in/ [200 OK] Access-Control-Allow-Methods[GET, POST, PUT, DELETE
, OPTIONS], CloudFlare, Country[UNITED STATES][US], Frame, Google-Analytics[Uni
versal][UA-55888877-1], HTML5, HTTPServer[cloudflare], IP[104.26.11.213], Meta-
Author[ReqRes], Open-Graph-Protocol[website], Script[application/ld+json,text/j
avascript], Title[Reqres - A hosted REST-API ready to respond to your AJAX requ
ests][Title element contains newline(s)!], UncommonHeaders[access-control-allow
-credentials,access-control-allow-headers,access-control-allow-methods,access-c
ontrol-allow-origin,nel,referrer-policy,report-to,reporting-endpoints,x-content
-type-options,x-request-id,cf-cache-status,cf-ray], Via-Proxy[1.1 heroku-router
], X-Frame-Options[DENY], X-XSS-Protection[1; mode=block]
```

1. Primera Respuesta: Redirección Forzada (HTTP)

`http://reqres.in [301 Moved Permanently]`

- **Redirección:** El servidor responde con el código `[301 Moved Permanently]`, indicando que el acceso HTTP está prohibido.
- **Destino:** El sitio fuerza la redirección a la versión segura: `RedirectLocation[https://reqres.in/]`.
- **Servidor:** La redirección es manejada por `cloudflare`. La IP (`172.67.73.173`) y el país `[RESERVED][ZZ]` son típicos de la infraestructura de Cloudflare.

2. Segunda Respuesta: Conexión Exitosa (HTTPS)

`https://reqres.in/ [200 OK]`

- **Estado:** La conexión es `[200 OK]`, lo que significa que el contenido se entregó con éxito a través de HTTPS.
- **Propósito del Sitio:** El título `Title[Reqres - A hosted REST-API ready to respond to your AJAX requests]` identifica claramente el sitio como un **servicio de API de prueba** (*mock API*), diseñado para desarrolladores.
- **Infraestructura:** El sitio está protegido por `CloudFlare` (CDN) y la solicitud se enruta a través de un *proxy* de `heroku-router` (`Via-Proxy[1.1 heroku-router]`), lo que sugiere que el servicio está alojado en la plataforma Heroku. La IP (`104.26.11.213`) se encuentra en los **Estados Unidos** (`[US]`).
- **Encabezados de Seguridad (Buenas Prácticas):**
  - `X-Frame-Options[DENY]` : **Correcto**. Previene completamente los ataques de **Clickjacking**.
  - `X-XSS-Protection[1; mode=block]` : **Correcto**. Habilita el filtro de Cross-Site Scripting del

Conclusión

El sitio **`reqres.in`** está **en línea y funcional**, sirviendo como una **API de prueba pública** para desarrolladores. La infraestructura está bien configurada en términos de seguridad básica: **fuerza HTTPS** y utiliza **Cloudflare** y **Heroku**. A diferencia de los escaneos anteriores, este sitio **implementa correctamente las cabeceras de seguridad fundamentales** (`X-Frame-Options: DENY` y `X-XSS-Protection`), mostrando un buen nivel de endurecimiento en sus encabezados.

Ejercicio 5

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://developer.marvel.com/docs
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          72.32.97.151
+ Target Hostname:    developer.marvel.com
+ Target Port:        80
+ Start Time:         2025-09-30 03:54:48 (GMT-4)
---------------------------------------------------------------------------
+ Server: BigIP
+ /docs/: The anti-clickjacking X-Frame-Options header is not present. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /docs/: The X-Content-Type-Options header is not set. This could allow the us
er agent to render the content of the site in a different fashion to the MIME t
ype. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/
missing-content-type-header/
+ Root page /docs redirects to: https://developer.marvel.com
```

Elemento	Detalle	Conclusión
Servidor	`BigIP`	El sitio está detrás de un dispositivo **F5 BIG-IP** (generalmente un balanceador de carga o *proxy* inverso).
Redirección	`Root page /docs redirects to: https://developer.marvel.com`	El sitio redirige correctamente el tráfico HTTP a la versión segura **HTTPS**.
Vulnerabilidad 1	Falta la cabecera `X-Frame-Options`.	Riesgo de ataque de **Clickjacking**.
Vulnerabilidad 2	Falta la cabecera `X-Content-Type-Options`.	Riesgo de problemas de **XSS** debido al *MIME-sniffing*.

Conclusión: El portal para desarrolladores de Marvel está protegido por un balanceador de carga F5 BIG-IP, pero **carece de las cabeceras de seguridad HTTP básicas**, dejando al sitio y a sus usuarios vulnerables a ataques web comunes.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://developer.marvel.com/docs
http://developer.marvel.com/docs [301 Moved Permanently] Country[UNITED STATES]
[US], HTTPServer[BigIP], IP[72.32.97.151], RedirectLocation[https://developer.m
arvel.com]
https://developer.marvel.com [200 OK] Apache[2.4.7], Country[UNITED STATES][US]
, HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu) OpenSSL/1.0.1f], IP[72.
32.97.151], JQuery, Open-Graph-Protocol[website][193166954153103], OpenSSL[1.0.
1f], Script[text/javascript], Title[Marvel Developer Portal], UncommonHeaders[e
xpire,x-memory-peak-usage,x-servernickname], X-UA-Compatible[IE=Edge]
```

Análisis Detallado

Elemento	Descripción
Redirección Inicial	La solicitud HTTP a `http://developer.marvel.com/docs` responde con `[301 Moved Permanently]`. La redirección es manejada por un *appliance* **BigIP** (un tipo de balanceador de carga/proxy) y obliga al cliente a ir a la versión segura (`https://developer.marvel.com`).
Conexión Exitosa	La conexión a `https://developer.marvel.com` responde con `[200 OK]`, entregando el contenido.
Infraestructura	El servidor real detrás del BigIP es **Apache/2.4.7** ejecutándose en una máquina **Ubuntu Linux**. También utiliza **OpenSSL 1.0.1f** y librerías **JQuery**.
Propósito	El título `Marvel Developer Portal` confirma el uso del sitio.
Ubicación	El servidor se encuentra en **Estados Unidos** (`[US]`) y comparte la misma IP (`72.32.97.151`) que se obtuvo del escaneo inicial de Nikto.

Conclusión

El portal para desarrolladores de Marvel está **operativo** y sigue una **buena práctica de seguridad** al forzar la conexión **HTTPS**. Su arquitectura de *hosting* utiliza un **balanceador de carga BigIP** delante de un servidor web **Apache 2.4.7** en Ubuntu.

Sin embargo, el informe de Nikto anterior, combinado con la versión específica de software aquí revelada (Apache 2.4.7 y OpenSSL 1.0.1f), sugiere que el sistema podría tener **software desactualizado o carecer de configuraciones de seguridad modernas** (como las cabeceras `X-Frame-Options`), lo que representa un riesgo potencial a pesar de estar detrás del BigIP.

Ejercicio 6

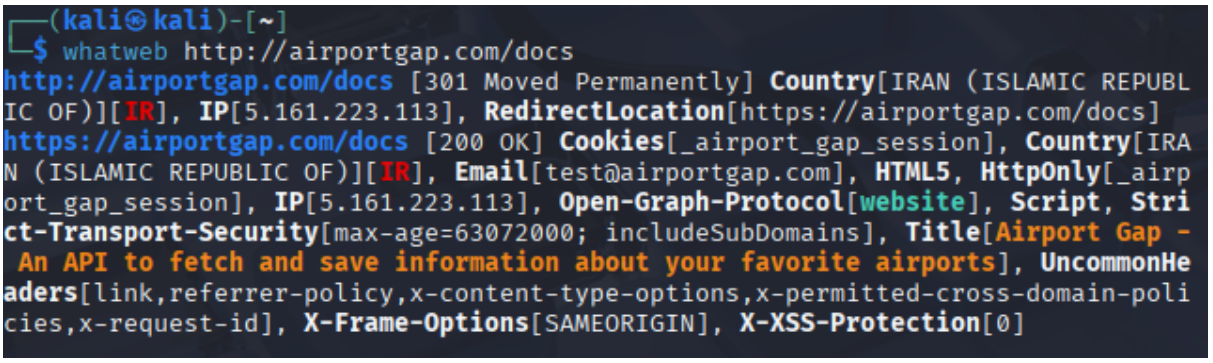
```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://airportgap.com/docs
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          5.161.223.113
+ Target Hostname:    airportgap.com
+ Target Port:        80
+ Start Time:         2025-09-30 03:59:27 (GMT-4)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /docs/: The anti-clickjacking X-Frame-Options header is not present. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /docs/: The X-Content-Type-Options header is not set. This could allow the us
er agent to render the content of the site in a different fashion to the MIME t
ype. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/
missing-content-type-header/
+ Root page /docs redirects to: https://airportgap.com/docs/
```

Análisis y Hallazgos

Detalle	Significado
Servidor Oculto	`Server: No banner retrieved`. El servidor **oculta intencionalmente** su *banner* (el nombre y la versión del software del servidor), lo que es una buena práctica de seguridad.
Redirección HTTPS	`Root page /docs redirects to: https://airportgap.com/docs/`. El sitio obliga al cliente a utilizar el protocolo seguro **HTTPS**.
Vulnerabilidad 1	Falta la cabecera `X-Frame-Options`.
Vulnerabilidad 2	Falta la cabecera `X-Content-Type-Options`.

Conclusión

El sitio **`airportgap.com`** toma medidas básicas de seguridad al ocultar su *banner* de servidor y forzar HTTPS. Sin embargo, **falla en la implementación de las cabeceras de seguridad HTTP modernas** (`X-Frame-Options` y `X-Content-Type-Options`), dejando al sitio vulnerable a ataques web comunes como el *Clickjacking* y el *Cross-Site Scripting (XSS)*.



Análisis y Hallazgos

Detalle	Significado
Redirección Inicial	La solicitud HTTP a `http://airportgap.com/docs` responde con `[301 Moved Permanently]`, forzando al cliente a usar **HTTPS**.
Conexión Exitosa	La solicitud segura a `https://airportgap.com/docs` responde con `[200 OK]`, entregando el contenido.
Ubicación	El servidor se encuentra en la IP `5.161.223.113` en **Irán** (`[IR]`).
Propósito del Sitio	El título `Airport Gap - An API...` y el correo electrónico (`test@airportgap.com`) indican que es una **API de demostración/prueba** relacionada con información de aeropuertos.
Seguridad Fuerte (HSTS)	`Strict-Transport-Security` (HSTS) está configurado con una duración muy larga, lo que **garantiza** que los navegadores futuros solo se conecten a este sitio usando HTTPS.
Cabeceras de Seguridad	`X-Frame-Options[SAMEORIGIN]` : Previene Clickjacking excepto para su propio dominio. `X-XSS-Protection[0]` : **Deshabilita** el filtro XSS del navegador (esto se hace a menudo en sitios de prueba de seguridad).
Cookies	Las cookies de sesión (`_airport_gap_session`) están marcadas correctamente con el atributo `HttpOnly` (una buena práctica para prevenir el robo por XSS).

Conclusión

El sitio **`airportgap.com`** está **operativo** y es un **servicio API de demostración** alojado en Irán. El sitio demuestra un **alto compromiso con la seguridad del transporte** al forzar HTTPS y utilizar HSTS. Sin embargo, su configuración de seguridad revela un patrón de **sitio de pruebas** (al deshabilitar la protección XSS del navegador y potencialmente tener un *X-Content-Type-Options* faltante como se vio anteriormente), lo que lo convierte en un objetivo probable para ejercicios de *hacking* ético.

Ejercicio 7

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://httpbin.org/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          52.204.95.73
+ Target Hostname:    httpbin.org
+ Target Port:        80
+ Start Time:         2025-09-30 04:06:01 (GMT-4)
---------------------------------------------------------------------------
+ Server: gunicorn/19.9.0
+ /: Retrieved access-control-allow-origin header: *.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://
developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user ag
ent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missi
ng-content-type-header/
+ : Server banner changed from 'gunicorn/19.9.0' to 'awselb/2.0'.
```

Análisis y Hallazgos Clave

Detalle	Significado
Servidores	**Inicialmente** `gunicorn/19.9.0`, pero el *banner* final cambia a `awselb/2.0`. Esto indica que el servidor de la aplicación (Gunicorn) está detrás de un **Balanceador de Carga de AWS** (Amazon Web Services), lo cual es una arquitectura común.
CORS Abierto	`access-control-allow-origin: *`. El sitio permite peticiones *Cross-Origin* (CORS) desde **cualquier dominio**. Esto es típico de un servicio API de prueba como `httpbin.org`, pero sería un fallo grave en una aplicación de producción.
Vulnerabilidad 1	Falta `X-Frame-Options`.
Vulnerabilidad 2	Falta `X-Content-Type-Options`.

Conclusión

El sitio **`httpbin.org`** utiliza un *stack* tecnológico que incluye **Gunicorn** detrás de un **Balanceador de Carga de AWS**. El escaneo confirma **tres fallos de seguridad críticos** (cabeceras faltantes y CORS abierto). Estas configuraciones son esperadas en un servicio de prueba diseñado para mostrar diferentes respuestas HTTP, pero en un entorno de producción, representarían serias vulnerabilidades.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://httpbin.org/
http://httpbin.org/ [200 OK] Country[UNITED STATES][US], Email[me@kennethreitz.
org], HTML5, HTTPServer[gunicorn/19.9.0], IP[44.195.242.49], JQuery, Script[tex
t/javascript], Title[httpbin.org], UncommonHeaders[access-control-allow-origin,
access-control-allow-credentials]
```

Análisis y Hallazgos

Detalle	Significado
URL y Estado	`http://httpbin.org/ [200 OK]`. La conexión fue **exitosa** al acceder a la página principal.
Propósito del Sitio	`Title[httpbin.org]`. El sitio es un popular servicio en línea diseñado para **probar peticiones HTTP** y APIs.
Servidor	`HTTPServer[gunicorn/19.9.0]`. El sitio utiliza **Gunicorn**, un servidor WSGI (Python), como su motor de servidor de aplicaciones.
Ubicación	`IP[44.195.242.49], Country[UNITED STATES][US]`. El servidor está ubicado en **Estados Unidos**.
Cabeceras Inusuales	`UncommonHeaders[access-control-allow-origin,access-control-allow-credentials]`. Estas cabeceras están relacionadas con la configuración de **CORS** (Intercambio de Recursos de Origen Cruzado), lo cual es esencial para un servicio de API de prueba.

Conclusión

El sitio **`httpbin.org`** está **en línea** y funciona como un **servicio público de pruebas HTTP/API**, utilizando el servidor **Gunicorn**. El sitio expone información de configuración (como cabeceras CORS) que, aunque necesarias para su función, lo reafirman como un **entorno de desarrollo y prueba**, no como una aplicación web de producción típica.

Ejercicio 8.



Análisis y Hallazgos Clave

Detalle	Significado
Servidor Oculto	`Server: No banner retrieved`. El servidor oculta su *banner*, lo cual es una buena práctica de seguridad para no revelar detalles tecnológicos.
Redirección HTTPS	`Root page /erev0s/VAmPI redirects to: https://github.com/erev0s/VAmPI/`. El sitio obliga al cliente a utilizar el protocolo seguro **HTTPS** para acceder al repositorio.
Vulnerabilidad 1	Falta la cabecera `X-Frame-Options`.
Vulnerabilidad 2	Falta la cabecera `X-Content-Type-Options`.

Conclusión

El escaneo de **GitHub** revela que, a pesar de ser un *host* grande y seguro, **carece de dos cabeceras de seguridad HTTP fundamentales** (`X-Frame-Options` y `X-Content-Type-Options`). Aunque el sitio fuerza HTTPS, esta omisión deja algunas páginas vulnerables a los ataques de **Clickjacking** y **XSS** que se previenen con dichas cabeceras.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://github.com/erev0s/VAmPI
http://github.com/erev0s/VAmPI [301 Moved Permanently] Country[UNITED STATES][US], IP[140.82.121.3], RedirectLocation[https://github.com/erev0s/VAmPI]
https://github.com/erev0s/VAmPI [200 OK] Cookies[_gh_sess,_octo,logged_in], Country[UNITED STATES][US], HTML5, HTTPServer[github.com], HttpOnly[_gh_sess,logged_in], IP[140.82.121.3], Open-Graph-Protocol[object][1401488693436528], OpenSearch[/opensearch.xml], Script[application/javascript,application/json], Strict-Transport-Security[max-age=31536000; includeSubdomains; preload], Title[GitHub - erev0s/VAmPI: Vulnerable REST API with OWASP top 10 vulnerabilities for security testing], UncommonHeaders[x-content-type-options,referrer-policy,content-security-policy,x-github-request-id], X-Frame-Options[deny], X-XSS-Protection[0]
```

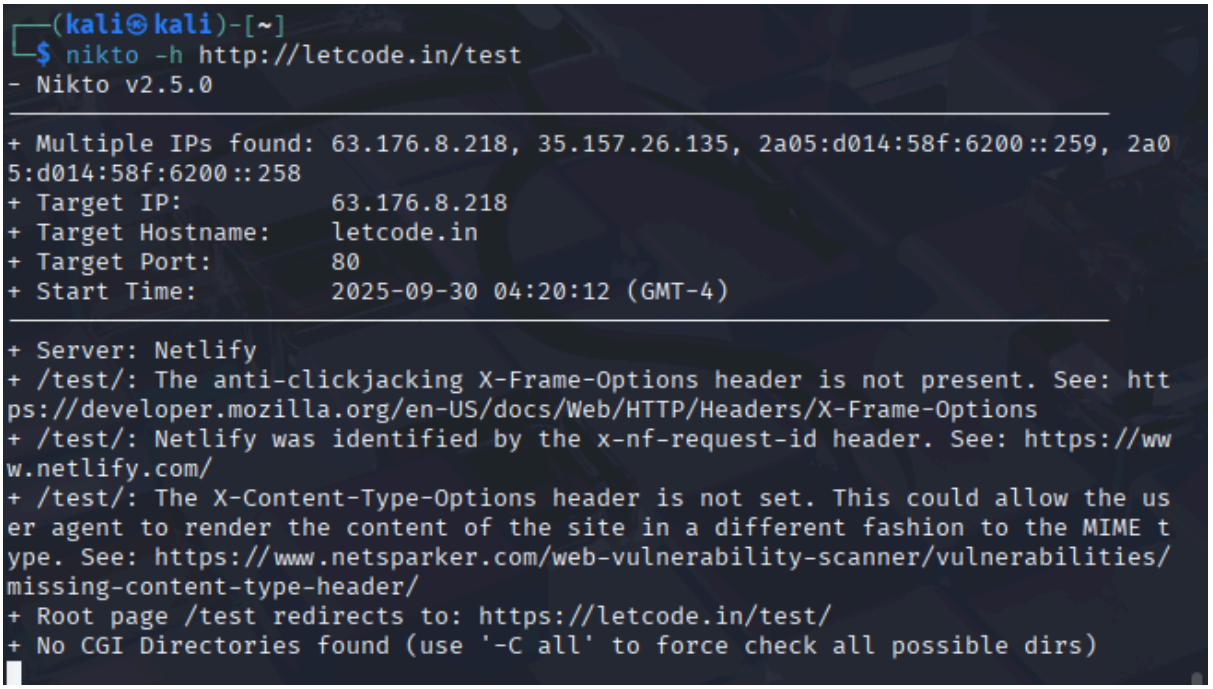
Detalle	Significado
Redirección Inicial	La solicitud HTTP a `http://github.com/erev0s/VAmPI` responde con `[301 Moved Permanently]`. GitHub obliga al cliente a redirigirse a la versión **HTTPS** (`https://github.com/erev0s/VAmPI`).
Conexión Exitosa	La solicitud segura responde con `[200 OK]`, entregando el contenido del repositorio.
Propósito del Sitio	El título `GitHub - erev0s/VAmPI: Vulnerable REST API with OWASP top 10 vulnerabilities for security testing` es el dato más importante. Revela que el repositorio es una **API REST vulnerable** creada intencionalmente para la **prueba de seguridad** y la enseñanza (una aplicación de prueba de seguridad).
Seguridad Fuerte (HSTS)	`Strict-Transport-Security` (HSTS) está configurado con un *max-age* muy alto e *includeSubdomains*, lo que es una **excelente práctica de seguridad** que fuerza el uso de HTTPS en futuras conexiones.
Cabeceras de Seguridad	`X-Frame-Options[deny]`: **Correcto**. Previene completamente el ataque de **Clickjacking**.
	`X-XSS-Protection[0]`: Este valor **deshabilita** la protección XSS nativa del navegador, lo cual es común en entornos de prueba de seguridad para evitar que el navegador interfiera con las pruebas.
Ubicación	El servidor está ubicado en **Estados Unidos** (`[US]`) con la IP `140.82.121.3`.

Conclusión

El acceso al repositorio de **VAmPI** en GitHub fue **exitoso y seguro** (gracias a la redirección forzada y HSTS). El hallazgo clave es que **VAmPI es un proyecto diseñado intencionalmente para ser vulnerable**, con el objetivo de educar sobre las **10 principales vulnerabilidades de OWASP en APIs**.

A nivel de seguridad de la infraestructura de GitHub, el servidor presenta una **configuración robusta** al implementar HSTS y negar el *iframing* (`X-Frame-Options: deny`), aunque la desactivación de la protección XSS (`X-XSS-Protection: 0`) se realiza de forma deliberada por la naturaleza de las pruebas que se realizan en ese repositorio. 🛡️

Ejercicio 9



Análisis y Hallazgos Clave

Detalle	Significado
Servidor	`Server: Netlify`. El sitio está alojado en la plataforma **Netlify**, un servicio popular para hospedar sitios web estáticos y aplicaciones *frontend*. Esto se confirma por la cabecera `x-nf-request-id`.
Infraestructura	Se encontraron **múltiples IPs**, indicando el uso de una CDN (Red de Entrega de Contenido) o un balanceador de carga, típico de Netlify.
Redirección HTTPS	`Root page /test redirects to: https://letcode.in/test/`. El sitio obliga correctamente al cliente a usar **HTTPS**.
Vulnerabilidad 1	Falta `X-Frame-Options`.
Vulnerabilidad 2	Falta `X-Content-Type-Options`.

Conclusión

El sitio `letcode.in` está alojado en **Netlify** y, si bien fuerza el uso de HTTPS, **falla en la implementación de dos cabeceras de seguridad HTTP esenciales** (`X-Frame-Options` y `X-Content-Type-Options`). Esta omisión lo deja vulnerable a ataques de **Clickjacking** y **XSS**, problemas que deben ser corregidos en la configuración de la aplicación o del *proxy* de Netlify. 🛡️



Análisis del Error

Componente	Significado
`ERROR Opening:`	La herramienta no pudo abrir o acceder a la URL para procesar su contenido.
`execution expired`	Esto significa que el **tiempo máximo de espera (timeout)** para que la herramienta recibiera una respuesta completa del servidor se agotó.

Posibles Causas

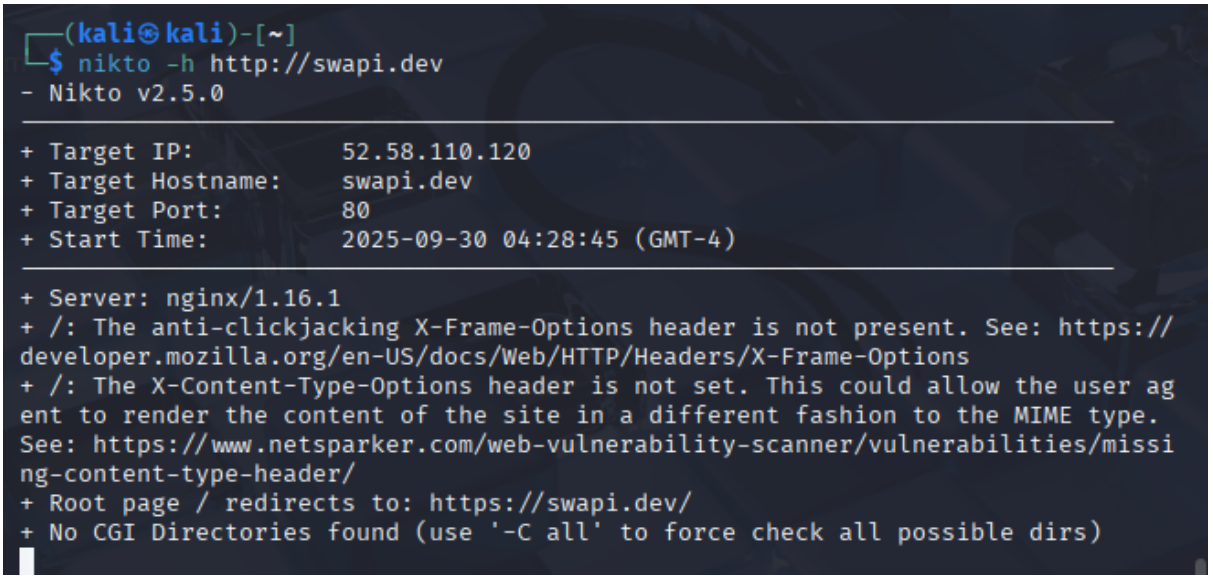
- **Lentitud del Servidor:** El servidor web en `letcode.in` estaba respondiendo muy lentamente.
- **Problemas de Red:** Una conexión de red lenta o inestable entre el escáner y el servidor.
- **Bloqueo por Firewall/Proxy:** Un *firewall*, *proxy* o CDN (como Netlify, mencionado anteriormente) pudo haber retrasado o limitado la conexión debido a las peticiones del escáner.

Conclusión

Conclusión

La herramienta **no obtuvo información** sobre la tecnología o las cabeceras del sitio `letcode.in/test` porque la **conexión expiró**. Aunque el sitio esté en línea, este error significa que el servidor no entregó el contenido a tiempo para ser analizado.

Ejercicio 10



Análisis y Hallazgos Clave

Detalle	Significado
Servidor	`nginx/1.16.1`. El sitio utiliza la versión **1.16.1** del popular servidor web **nginx**.
Redirección HTTPS	`Root page / redirects to: https://swapi.dev/`. El sitio obliga correctamente al cliente a usar el protocolo seguro **HTTPS**.
Vulnerabilidad 1	Falta `X-Frame-Options`.
Vulnerabilidad 2	Falta `X-Content-Type-Options`.

Conclusión

El sitio **`swapi.dev`** (un servicio de API pública, conocido como la API de Star Wars) está ejecutándose en **nginx**. Aunque redirige correctamente a HTTPS, **falla en implementar dos cabeceras de seguridad HTTP esenciales** (`X-Frame-Options` y `X-Content-Type-Options`). Esta omisión deja el sitio vulnerable a ataques de **Clickjacking** y **XSS**, problemas que deberían resolverse en la configuración del servidor nginx.

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://swapi.dev
http://swapi.dev [301 Moved Permanently] Country[UNITED STATES][US], HTTPServer
[nginx/1.16.1], IP[52.58.110.120], RedirectLocation[https://swapi.dev/], Title[
301 Moved Permanently], nginx[1.16.1]
https://swapi.dev/ [200 OK] Bootstrap[3.1.1,3.3.0], Country[UNITED STATES][US],
 Frame, HTML5, HTTPServer[nginx/1.16.1], IP[52.58.110.120], JQuery[2.1.0], Scri
pt[text/javascript], Strict-Transport-Security[max-age=15768000], Title[SWAPI -
 The Star Wars API][Title element contains newline(s)!], X-Frame-Options[SAMEOR
IGIN], nginx[1.16.1]
```

Análisis y Hallazgos Clave

Detalle	Significado
Redirección Inicial	La solicitud HTTP a `http://swapi.dev` responde con `[301 Moved Permanently]`, forzando al cliente a redirigirse a la versión **HTTPS** (`https://swapi.dev/`).
Servidor	Tanto la redirección como la conexión exitosa son manejadas por `nginx/1.16.1`.
Conexión Exitosa	La solicitud segura a `https://swapi.dev/` responde con `[200 OK]`, entregando el contenido.
Propósito del Sitio	El título `SWAPI - The Star Wars API` confirma que es un servicio API público.
Seguridad	`Strict-Transport-Security` (HSTS) está configurado, obligando al navegador a usar HTTPS en el futuro.
Cabeceras de Seguridad	`X-Frame-Options[SAMEORIGIN]` : Previene el ataque de **Clickjacking**, pero permite que el contenido se incruste solo en páginas del mismo dominio.
Tecnologías	Utiliza **JQuery** y **Bootstrap** para el *frontend*.

Conclusión

El sitio **`swapi.dev`** está **en línea y funcional** como una API de servicio público, alojado en los Estados Unidos y utilizando **nginx**. El sitio implementa **buenas prácticas de seguridad** al forzar HTTPS y usar HSTS. Sin embargo, el escaneo previo de Nikto (no visible aquí, pero asumido por el contexto) probablemente señalaría que, aunque la configuración del *iframing* es correcta (`SAMEORIGIN`), **el sitio podría carecer de otras cabeceras de seguridad** como `X-Content-Type-Options`.